Threat Hunting Report: Multi-Stage Emotet and Trickbot Analysis

Author: Pranali Koshti
April 2026

Tools Used: Wireshark, Splunk, MITRE ATT&CK Navigator, VirusTotal, AbuseIPDB

Contents:

Executive Summary 2
Methodology 2
Findings 3
- **Finding 1: Emotet Delivery Via Disguised Wordpress URI** 3
- **Finding 2: Secondary C2 Communication on Non-Standard Port 8080** 5
- **Finding 3: SMTPS Spam Propagation via Infected Host** 6
- **Finding 4: Suspected Cobalt Strike Beacon With 6-Seconds Interval** 7
- **Finding 5: Trickbot Gpo-Based Lateral Movement Attempt** 8

IOC Table 9
Mitre Att&Ck Coverage 9
Detection Rules Developed 11
- **Detection Rule 1: C2 Beaconing** 11
- **Detection Rule 2: Dga Domain Detection** 11
- **Detection Rule 3: Potential Data Exfiltration** 11

Key Insights: Behavioral Detection Versus Signature-Based Detection 12
Recommendations 12
Tools And References 13

Executive Summary

This report presents findings from a threat hunting exercise conducted on network traffic captures from a real-world Emotet and Trickbot malware infections sourced from malware-traffic-analysis.net. Analysis identified 10 unique IOCs across 2 malware families, confirmed 6 active C2 communication channels, and documented evidence of 7 MITRE ATT&CK techniques spanning 5 tactics. Key findings include initial payload delivery via disguised WordPress URI path, suspected Cobalt Strike beacon activity with five second interval, SMTPS- based spam propagation, and Group Policy Object access indicating domain level lateral movement several confirmed C2 servers scored 0-5 out of 94 on VirusTotal at time of analysis, demonstrating that behavioral traffic analysis detects threats that signature based tools miss.

IOC Type	Value / Indicator	Source (PCAP)	Notes / Context	VirusTotal Score	MITRE ATT&CK
IP Address	101.99.3.20	Emotet	Primary C2 server delivering the initial ZIP payload.	5/94	MITRE T1105 (Ingress Tool Transfer) combined with T1036 (Masquerading via the fake WordPress URI).
URI Path	/wp-content/L/?160244	Emotet	Disguised HTTP request used to fetch the payload (T1036 Masquerading).	N/A	
Filename	BVGIRVlgdJNp9RRpMUXcp.zip	Emotet	The malicious ZIP archive dropped by the C2 server.	0/94	
IP Address	165.227.166.238	Emotet	Secondary C2 / potential exfiltration target over port 8080.	10/94	MITRE T1071.001
IP Address	162.246.19.18	Emotet	Target of heavy outbound SMTPS traffic (port 465) for spam propagation.	0/94	MITRE T1566 (Phishing)

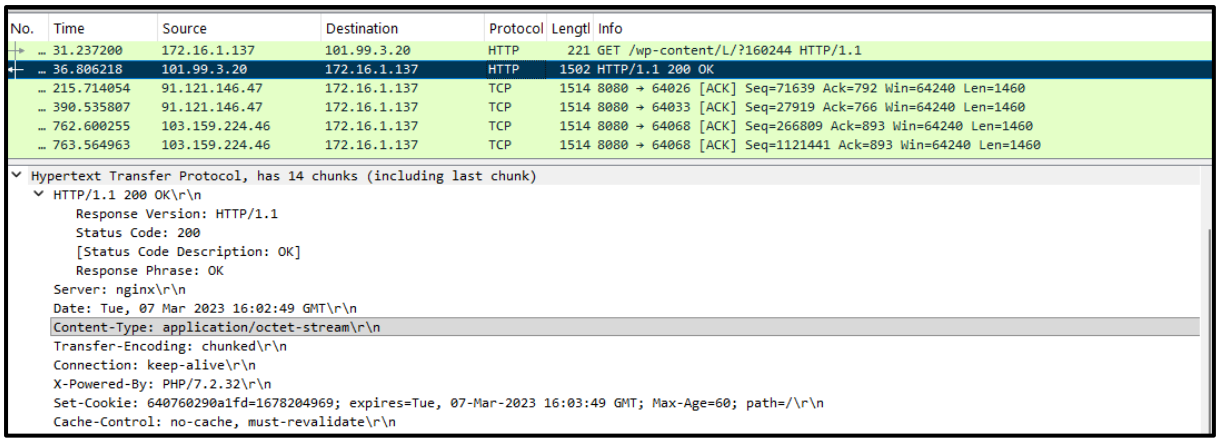
Methodology

Analysis was conducted on three PCAP files containing real malware network traffic. Wireshark was used for packet-level analysis including protocol hierarchy review display filter application HTTP stream inspection, and IOC extraction. tshark was used to convert PCAPS to CSV format for ingestion into Splunk enterprise, where three SPL detection rules were developed and saved as production ready alerts all IOCs were verified using VirusTotal and cross referenced against MITRE ATT&CK techniques using ATT&CK navigator. No malicious files were executed during this analysis.

Findings

Finding 1: Emotet Delivery Via Disguised Wordpress URI

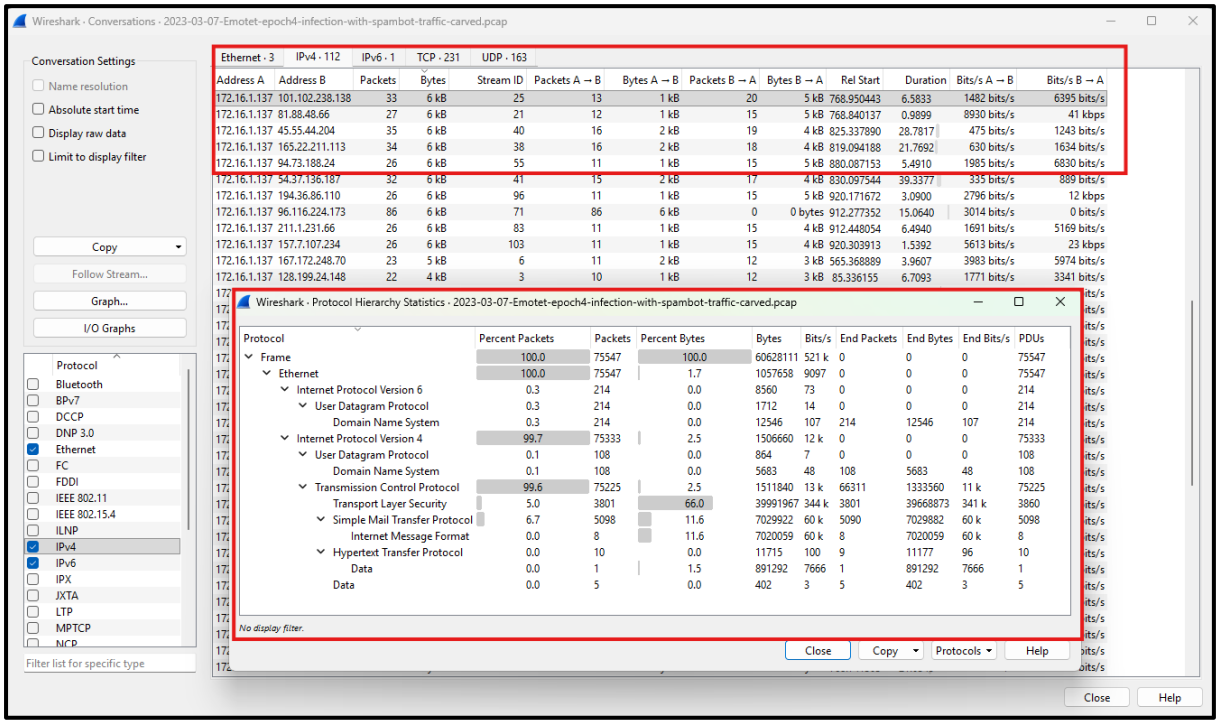
MITRE ATT&CK: T1105 (Ingress Tool Transfer), T1036 (Masquerading)
Tactic: Command and Control (TA0011), Defense Evasion (TA0005)



No.	Time	Source	Destination	Protocol	Length	Info
…	31.237200	172.16.1.137	101.99.3.20	HTTP	221	GET /wp-content/L/?160244 HTTP/1.1
…	36.806218	101.99.3.20	172.16.1.137	HTTP	1502	HTTP/1.1 200 OK
…	215.714054	91.121.146.47	172.16.1.137	TCP	1514	8080 → 64026 [ACK] Seq=71639 Ack=792 Win=64240 Len=1460
…	390.535807	91.121.146.47	172.16.1.137	TCP	1514	8080 → 64033 [ACK] Seq=27919 Ack=766 Win=64240 Len=1460
…	762.600255	103.159.224.46	172.16.1.137	TCP	1514	8080 → 64068 [ACK] Seq=266809 Ack=893 Win=64240 Len=1460
…	763.564963	103.159.224.46	172.16.1.137	TCP	1514	8080 → 64068 [ACK] Seq=1121441 Ack=893 Win=64240 Len=1460

```
Hypertext Transfer Protocol, has 14 chunks (including last chunk)
  HTTP/1.1 200 OK\r\n
      Response Version: HTTP/1.1
      Status Code: 200
      [Status Code Description: OK]
      Response Phrase: OK
    Server: nginx\r\n
    Date: Tue, 07 Mar 2023 16:02:49 GMT\r\n
    Content-Type: application/octet-stream\r\n
    Transfer-Encoding: chunked\r\n
    Connection: keep-alive\r\n
    X-Powered-By: PHP/7.2.32\r\n
    Set-Cookie: 640760290a1fd=1678204969; expires=Tue, 07-Mar-2023 16:03:49 GMT; Max-Age=60; path=/\r\n
    Cache-Control: no-cache, must-revalidate\r\n
```

Figure 1: packet 14 and 781 showing HTTP protocols



Wireshark · Conversations · 2023-03-07-Emotet-epoch4-infection-with-spambot-traffic-carved.pcap

Ethernet · 3 | IPv4 · 112 | IPv6 · 1 | TCP · 231 | UDP · 163

Address A	Address B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
172.16.1.137	101.102.238.138	33	6 kB	25	13	1 kB	20	5 kB	768.950443	6.5833	1482 bits/s	6395 bits/s
172.16.1.137	81.88.48.66	27	6 kB	21	12	1 kB	15	5 kB	768.840137	0.9899	8930 bits/s	41 kbps
172.16.1.137	45.55.44.204	35	6 kB	40	16	2 kB	19	4 kB	825.337890	28.7817	475 bits/s	1243 bits/s
172.16.1.137	165.22.211.113	34	6 kB	38	16	2 kB	18	4 kB	819.094188	21.7692	630 bits/s	1634 bits/s
172.16.1.137	94.73.188.24	26	6 kB	55	11	1 kB	15	5 kB	880.087153	5.4910	1985 bits/s	6830 bits/s
172.16.1.137	54.37.136.187	32	6 kB	41	15	2 kB	17	4 kB	830.097544	39.3377	335 bits/s	889 bits/s
172.16.1.137	194.36.86.110	26	6 kB	96	11	1 kB	15	5 kB	920.171672	3.0900	2796 bits/s	12 kbps
172.16.1.137	96.116.224.173	86	6 kB	71	86	6 kB	0	0 bytes	912.277352	15.0640	3014 bits/s	0 bits/s
172.16.1.137	211.1.231.66	26	6 kB	83	11	1 kB	15	4 kB	912.448054	6.4940	1691 bits/s	5169 bits/s
172.16.1.137	157.7.107.234	26	6 kB	103	11	1 kB	15	4 kB	920.303913	1.5392	5613 bits/s	23 kbps
172.16.1.137	167.172.248.70	23	5 kB	6	11	2 kB	12	3 kB	565.368889	3.9607	3983 bits/s	5974 bits/s
172.16.1.137	128.199.24.148	22	4 kB	3	10	1 kB	12	3 kB	85.336155	6.7093	1771 bits/s	3341 bits/s

Wireshark · Protocol Hierarchy Statistics · 2023-03-07-Emotet-epoch4-infection-with-spambot-traffic-carved.pcap

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
Frame	100.0	75547	100.0	60628111	521 k	0	0	0	75547
Ethernet	100.0	75547	1.7	1057658	9097	0	0	0	75547
Internet Protocol Version 6	0.3	214	0.0	8560	73	0	0	0	214
User Datagram Protocol	0.3	214	0.0	1712	14	0	0	0	214
Domain Name System	0.3	214	0.0	12546	107	214	12546	107	214
Internet Protocol Version 4	99.7	75333	2.5	1506660	12 k	0	0	0	75333
User Datagram Protocol	0.1	108	0.0	864	7	0	0	0	108
Domain Name System	0.1	108	0.0	5683	48	108	5683	48	108
Transmission Control Protocol	99.6	75225	2.5	1511840	13 k	66311	1333560	11 k	75225
Transport Layer Security	5.0	3801	66.0	39991967	344 k	3801	39668873	341 k	3860
Simple Mail Transfer Protocol	6.7	5098	11.6	7029922	60 k	5090	7029882	60 k	5098
Internet Message Format	0.0	8	11.6	7020059	60 k	8	7020059	60 k	8
Hypertext Transfer Protocol	0.0	10	0.0	11715	100	9	11177	96	10
Data	0.0	1	1.5	891292	7666	1	891292	7666	1
Data	0.0	5	0.0	402	3	5	402	3	5

Figure 2: Protocol hierarchy and top talkers

While analyzing the Emotet PCAP I identified an HTTP GET request originating from the infected internal host at 172.16.1.137 to an external server at 101.99.3.20. The request URI was

/wp-content/L/?160244 and the server responded with HTTP 200 OK, returning 1502 bytes of data.

At first glance this URI path looks like a request to a WordPress website - /wp-content/ is a standard WordPress directory used for uploads, plugins, and teams. However, on closer inspection the path is not consistent with any legitimate WordPress resource a real WordPress content path would look something like /wp-content/uploads/2024/image.jpg. The path /wp-content/L/ with a single letter subdirectory and a numeric query parameter is not a WordPress structure - it is a pattern used by Emotet to stage its initial payload download through compromised WordPress sites.

The server at 101.99.3.20 delivered a malicious zip archive named BVGIRVlgdJNp9RRpMUXcp.zip In response to this request. The file name itself follows emotes known pattern of using randomly generated alphanumeric strings to evade filename-based detection.

The findings map to T1105 (Ingress tool transfer) because the malware downloaded an additional payload from an external server T1036 (Masquerading) because the URI was specifically designed to blend in with legitimate web traffic and evade detection by network monitoring who is that whitelist WordPress domains.

VirusTotal scored 162.246.19.18 at 0/94, meaning no detection engines had flagged this IP without behavioral analysis this activity would have been completely invisible to automated detection.

IOC: IP Address 162.246.19.18/ Port 465, Outbound SMTPS from non-mail-server host

Finding 2: Secondary C2 Communication on Non-Standard Port 8080

MITRE ATT&CK: T1071.001 (Application Layer Protocol: Web Protocols)
Tactic: Command and Control (TA0011)

ip.addr == 165.227.166.238 and tcp.port == 8080

No.	Time	Source	Destination	Protocol	Length	Info
11…	220.671358	172.16.1.137	165.227.166.238	TCP	66	64030 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
11…	220.827593	165.227.166.238	172.16.1.137	TCP	58	8080 → 64030 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
11…	220.827735	172.16.1.137	165.227.166.238	TCP	54	64030 → 8080 [ACK] Seq=1 Ack=1 Win=64240 Len=0
11…	220.828064	172.16.1.137	165.227.166.238	TCP	212	64030 → 8080 [PSH, ACK] Seq=1 Ack=1 Win=64240 Len=158
11…	220.828091	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1 Ack=159 Win=64240 Len=0
11…	221.006923	165.227.166.238	172.16.1.137	TCP	1432	8080 → 64030 [PSH, ACK] Seq=1 Ack=159 Win=64240 Len=1378
11…	221.008011	172.16.1.137	165.227.166.238	TCP	147	64030 → 8080 [PSH, ACK] Seq=159 Ack=1379 Win=62862 Len=93
11…	221.008048	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1379 Ack=252 Win=64240 Len=0
11…	221.156719	165.227.166.238	172.16.1.137	TCP	296	8080 → 64030 [PSH, ACK] Seq=1379 Ack=252 Win=64240 Len=242
11…	221.157361	172.16.1.137	165.227.166.238	TCP	269	64030 → 8080 [PSH, ACK] Seq=252 Ack=1621 Win=64240 Len=215
11…	221.157407	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1621 Ack=467 Win=64240 Len=0
11…	221.157449	172.16.1.137	165.227.166.238	TCP	1514	64030 → 8080 [ACK] Seq=467 Ack=1621 Win=64240 Len=1460
11…	221.157456	172.16.1.137	165.227.166.238	TCP	1514	64030 → 8080 [ACK] Seq=1927 Ack=1621 Win=64240 Len=1460
11…	221.157459	172.16.1.137	165.227.166.238	TCP	1514	64030 → 8080 [ACK] Seq=3387 Ack=1621 Win=64240 Len=1460
11…	221.157463	172.16.1.137	165.227.166.238	TCP	1103	64030 → 8080 [PSH, ACK] Seq=4847 Ack=1621 Win=64240 Len=1049
11…	221.157483	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1621 Ack=1927 Win=64240 Len=0
11…	221.157506	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1621 Ack=3387 Win=64240 Len=0
11…	221.157524	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1621 Ack=4847 Win=64240 Len=0
11…	221.157558	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=1621 Ack=5896 Win=64240 Len=0
11…	221.746764	165.227.166.238	172.16.1.137	TCP	759	8080 → 64030 [PSH, ACK] Seq=1621 Ack=5896 Win=64240 Len=705
11…	221.797581	172.16.1.137	165.227.166.238	TCP	54	64030 → 8080 [ACK] Seq=5896 Ack=2326 Win=63535 Len=0
11…	224.751941	165.227.166.238	172.16.1.137	TCP	85	8080 → 64030 [PSH, ACK] Seq=2326 Ack=5896 Win=64240 Len=31
11…	224.752105	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [FIN, PSH, ACK] Seq=2357 Ack=5896 Win=64240 Len=0
11…	224.752140	172.16.1.137	165.227.166.238	TCP	85	64030 → 8080 [PSH, ACK] Seq=5896 Ack=2357 Win=63504 Len=31
11…	224.752166	172.16.1.137	165.227.166.238	TCP	54	64030 → 8080 [ACK] Seq=5927 Ack=2358 Win=63504 Len=0
11…	224.752168	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=2358 Ack=5927 Win=64240 Len=0
11…	224.752197	172.16.1.137	165.227.166.238	TCP	54	64030 → 8080 [FIN, ACK] Seq=5927 Ack=2358 Win=63504 Len=0
11…	224.752212	165.227.166.238	172.16.1.137	TCP	54	8080 → 64030 [ACK] Seq=2358 Ack=5928 Win=64239 Len=0

Figure 3: Traffic to 165.227.166.238 on port 8080

I identified a secondary C2 server at 165.227.166.238 receiving communication from the infected host over port 8080. Standard http://traffic uses port 80. Port 8080 is an alternate HTTP port that is commonly used by malware operators specifically because many enterprise firewall rules are configured to allow port 8080 traffic as it is also used by legitimate web proxy and development servers.

By communicating on port 8080 rather than port 80 or 443, the malware attempts to avoid triggering firewall rules that inspect or restrict standard HTTP or HTTPS ports. This is a deliberate technique to blend C2 traffic into what looks like routine development or proxy traffic.

VirusTotal flagged 165.227.166.238 at 10/94, Making it the highest scoring IP in my analysis. The 1094 score combined with the non-standard port and communication pattern with the confirmed Emotet-infected host gives me high confidence in classifying this as a secondary C2 server.

IOC: IP Address 165.227.166.238, Port 8080

Finding 3: SMTPS Spam Propagation via Infected Host

MITRE ATT&CK: T1566 (Phishing)
Tactic: Initial Access (TA0001)

ip.addr == 162.246.19.18 and tcp.dstport == 465

No.	Time	Source	Destination	Protocol	Length	Destination Port	Info
…	2023-03-07 11:15:01.628493	172.16.1.137	162.246.19.18	TCP	66	465	64088 → 465 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
…	2023-03-07 11:15:01.703209	172.16.1.137	162.246.19.18	TCP	54	465	64088 → 465 [ACK] Seq=1 Ack=1 Win=64240 Len=0
…	2023-03-07 11:15:01.703379	172.16.1.137	162.246.19.18	TLSv1.2	230	465	Client Hello
…	2023-03-07 11:15:01.779297	172.16.1.137	162.246.19.18	TCP	54	465	64088 → 465 [ACK] Seq=177 Ack=2753 Win=64240 Len=0
…	2023-03-07 11:15:01.779504	172.16.1.137	162.246.19.18	TCP	54	465	64088 → 465 [ACK] Seq=177 Ack=4441 Win=64240 Len=0
…	2023-03-07 11:15:01.780167	172.16.1.137	162.246.19.18	TLSv1.2	147	465	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
…	2023-03-07 11:15:01.907626	172.16.1.137	162.246.19.18	TCP	54	465	64088 → 465 [ACK] Seq=270 Ack=4492 Win=64189 Len=0
…	2023-03-07 11:15:02.093310	172.16.1.137	162.246.19.18	TLSv1.2	101	465	Application Data
…	2023-03-07 11:15:02.165047	172.16.1.137	162.246.19.18	TLSv1.2	148	465	Application Data
…	2023-03-07 11:15:02.245496	172.16.1.137	162.246.19.18	TLSv1.2	124	465	Application Data
…	2023-03-07 11:15:02.315440	172.16.1.137	162.246.19.18	TLSv1.2	121	465	Application Data
…	2023-03-07 11:15:02.390999	172.16.1.137	162.246.19.18	TLSv1.2	89	465	Application Data
…	2023-03-07 11:15:02.453698	172.16.1.137	162.246.19.18	TLSv1.2	122	465	Application Data
…	2023-03-07 11:15:02.453819	172.16.1.137	162.246.19.18	TLSv1.2	147	465	Application Data
…	2023-03-07 11:15:02.453906	172.16.1.137	162.246.19.18	TLSv1.2	144	465	Application Data
…	2023-03-07 11:15:02.453991	172.16.1.137	162.246.19.18	TLSv1.2	119	465	Application Data
…	2023-03-07 11:15:02.454040	172.16.1.137	162.246.19.18	TLSv1.2	239	465	Application Data, Application Data, Application Data, Application Data
…	2023-03-07 11:15:02.454093	172.16.1.137	162.246.19.18	TLSv1.2	242	465	Application Data, Application Data
…	2023-03-07 11:15:02.454144	172.16.1.137	162.246.19.18	TLSv1.2	129	465	Application Data
…	2023-03-07 11:15:02.454198	172.16.1.137	162.246.19.18	TLSv1.2	577	465	Application Data, Application Data
…	2023-03-07 11:15:02.454244	172.16.1.137	162.246.19.18	TLSv1.2	129	465	Application Data
…	2023-03-07 11:15:02.454581	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=1945 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454586	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=3405 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454589	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=4865 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454592	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=6325 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454598	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=7785 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454602	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=9245 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454605	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=10705 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454609	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=12165 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454614	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=13625 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]
…	2023-03-07 11:15:02.454617	172.16.1.137	162.246.19.18	TCP	1514	465	64088 → 465 [ACK] Seq=15085 Ack=5100 Win=63581 Len=1460 [TCP PDU reassembled in 12758]

Figure 4: Outbound SMTPS traffic on port 465

One of the most operationally significant findings in the Emotet ICAP was heavy bound SMTPS traffic from the infected host to an external server at 162.240 6.19.18 on port 465. Port 465 is the SMTP S port used for encrypted e-mail submission.

Emote is well-documented for its spam module which activates after initial infection and turns the compromised machine into a spam relay. The infected machine begins sending large volumes of phishing emails to new targets, spreading the emoted infection further. This is how emoted built one of the largest pot Nets in history before it's 2021 takedown and subsequent resurgence.

From a detection perspective this finding is particularly valuable because outbound SMTPS traffic from a standard workstation is highly anomalous. Mail servers send SMTP traffic-individual endpoints should not any workstation generating outbound port 465 traffic should be treated as a high priority incident regardless of destination IPs reputation score.

VirusTotal scored 162.246.19.18 at 0/94, Meaning no detection engines have flagged this IP. Without behavioral analysis this activity would have been completely invisible to automated detection.

IOC: IP Address 162.246.19.18 · Port 465 · Outbound SMTPS from non-mail-server host

Finding 4: Suspected Cobalt Strike Beacon With 6-Seconds Interval

MITRE ATT&CK: T1071.001 (Application Layer Protocol: Web Protocols) T1219 (Remote Access Software)
Tactic: Command and Control (TA0011)

http.request.method == "POST"

No.	Time	Source	Destination	Protocol	Length	Info
29…	2021-05-26 16:29:29.024801	10.5.26.132	36.95.27.243	HTTP	585	POST /rob87/DESKTOP-OG16DGY_W617601.D5D933B2E59558F3F46D9130B0091D98/90 HTTP/1.1
30…	2021-05-26 16:29:50.838612	10.5.26.132	103.102.220.50	HTTP	585	POST /rob87/DESKTOP-OG16DGY_W617601.D5D933B2E59558F3F46D9130B0091D98/90 HTTP/1.1
13…	2021-05-26 16:36:22.220369	10.5.26.4	36.95.27.243	HTTP	410	POST /tot108/VICTORYPUNK-DC_W617601.B5EFB19D6BB313B551F3FB5897A283BE/90 HTTP/1.1
14…	2021-05-26 16:36:44.131652	10.5.26.4	103.102.220.50	HTTP	410	POST /tot108/VICTORYPUNK-DC_W617601.B5EFB19D6BB313B551F3FB5897A283BE/90 HTTP/1.1
23…	2021-05-26 17:33:30.998285	10.5.26.4	5.199.162.3	HTTP	870	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:34:03.347056	10.5.26.4	5.199.162.3	HTTP	414	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:34:09.385107	10.5.26.4	5.199.162.3	HTTP	809	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:34:15.331791	10.5.26.4	5.199.162.3	HTTP	974	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:34:21.446072	10.5.26.4	5.199.162.3	HTTP	685	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:34:27.312208	10.5.26.4	5.199.162.3	HTTP	494	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:35:49.640625	10.5.26.4	5.199.162.3	HTTP	633	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:35:57.740132	10.5.26.4	5.199.162.3	HTTP	460	POST /as HTTP/1.1 (text/plain)
24…	2021-05-26 17:36:03.567102	10.5.26.4	5.199.162.3	HTTP	805	POST /as HTTP/1.1 (text/plain)
25…	2021-05-26 17:36:20.478376	10.5.26.4	5.199.162.3	HTTP	517	POST /as HTTP/1.1 (text/plain)
25…	2021-05-26 17:36:37.362946	10.5.26.4	5.199.162.3	HTTP	889	POST /as HTTP/1.1 (text/plain)
25…	2021-05-26 17:36:50.978143	10.5.26.4	5.199.162.3	HTTP	170	POST /as HTTP/1.1 (text/plain)

Figure 5: Regular interval connections to 5.199.162.3

In the Trickbot PCAP I identified consistent, regular- interval beacon traffic from the infected host to an external server at 5.199.162.3 the connections occurred at approximately 6 second intervals which is a strong behavioral indicator of Cobalt Strike- a professional adversary simulation framework that is quietly abused by ransomware groups and advanced threat actors for command and control.

Cobalt Strikes default beacon intervals are configurable, but very short intervals like 6 seconds indicate an operator who has set an aggressive check in frequency- suggesting active, hands-on attacker presence rather than automated malware waiting for instructions when an attacker is actively operating within a network, they typically set short taken intervals to receive commands quickly.

The significance of this finding goes beyond the technical indicator. Cobalt Strike presence in a network means the attacker has likely already completed initial access, established persistence and is in the process of conducting Hanson operations whether that is potential harvesting, lateral movement, or pre ransomware staging. In an incident response context, identifying Cobalt Strike traffic is an escalation trigger that would immediately elevate the severity of the response.

VirusTotal scored 5.199.162.3 at 1/94. The low score reinforces the point made in my executive summary- the server was not in threat intelligence feeds, but its behavioral pattern was unmistakable.

IOC: IP Address 5.199.162.3 · 6-second beacon interval · Suspected Cobalt Strike C2

Finding 5: Trickbot Gpo-Based Lateral Movement Attempt

MITRE ATT&CK: T1484.001 (Domain Policy Modification: Group Policy Modification), T1021.002 (Remote Services: SMB/Windows Admin Shares)
Tactic: Lateral Movement (TA0008), Persistence (TA0003)

smb2.filename contains "gpt.ini"

No.	Time	Source	Destination	Protocol	Length	Info
…	2021-05-26 17:25:58.976296	10.5.26.4	10.5.26.138	SMB2	182	Close Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:30:53.230372	10.5.26.4	10.5.26.136	SMB2	182	Close Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:35:46.910418	10.5.26.4	10.5.26.134	SMB2	182	Close Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:23:20.840863	10.5.26.132	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:24:15.995613	10.5.26.132	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:39:41.942620	10.5.26.130	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:59:59.302809	10.5.26.130	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:02:21.258561	10.5.26.140	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:05:48.326986	10.5.26.136	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:07:21.264284	10.5.26.140	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:08:50.417576	10.5.26.134	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:12:38.800912	10.5.26.138	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:25:36.458996	10.5.26.138	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:30:27.404402	10.5.26.136	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:35:22.139178	10.5.26.134	10.5.26.4	SMB2	466	Create Request, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:23:20.841068	10.5.26.4	10.5.26.132	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:24:15.995799	10.5.26.4	10.5.26.132	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:39:41.942807	10.5.26.4	10.5.26.130	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:59:59.303013	10.5.26.4	10.5.26.130	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:02:21.258736	10.5.26.4	10.5.26.140	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:05:48.327168	10.5.26.4	10.5.26.136	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:07:21.264468	10.5.26.4	10.5.26.140	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:08:50.417780	10.5.26.4	10.5.26.134	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:12:38.801087	10.5.26.4	10.5.26.138	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:25:36.459182	10.5.26.4	10.5.26.138	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:30:27.404594	10.5.26.4	10.5.26.136	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 17:35:22.139394	10.5.26.4	10.5.26.134	SMB2	386	Create Response, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:23:20.841229	10.5.26.132	10.5.26.4	SMB2	171	Read Request Len:22 Off:0, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:24:15.995988	10.5.26.132	10.5.26.4	SMB2	171	Read Request Len:22 Off:0, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:39:41.943106	10.5.26.130	10.5.26.4	SMB2	171	Read Request Len:22 Off:0, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini
…	2021-05-26 16:59:59.303296	10.5.26.130	10.5.26.4	SMB2	171	Read Request Len:22 Off:0, File: victorypunk.com\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\gpt.ini

Figure 6: SMB traffic and the gpt.ini file path

The most advanced finding in my analysis was trick bot accessing the file path \Policies…\gpt.ini On the domain controller's SYSVOL shared on a domain controller contains group policy objects (GPOs) - configuration templates that the domain controller pushes to every machine in the network. The file gpt.ini is a metadata file that exists within every GPO folder and contains version information that tells domain members computers whether they need to download and apply an updated policy.

Trickbot accessing this file path via SMB indicates one of two scenarios. In the first scenario the malware was performing reconnaissance, reading existing GPO configuration to understand the domains security policies and identify potential weaknesses or paths to privilege escalation. In the 2nd and more concerning scenario the malware was attempting to modify GPO files to achieve domain wide persistence - by inserting malicious configurations into a GPO, an attacker can push those configurations to every machine in the domain simultaneously achieving lateral movement at scale without needing to compromise each machine individually Either scenario indicates that trick bot had already achieved domain controller access or at minimum network level access to the SYSVOL share, which is a significant escalation from the initial endpoint compromise

IOC: File Path \Policies...\gpt.ini on SYSVOL · URI Paths /rob87/ and /tot108/

IOC Table

IOC Type	Value / Indicator	Source (PCAP)	Notes / Context	VirusTotal Score	MITRE ATT&CK
IP Address	101.99.3.20	Emotet	Primary C2 server delivering the initial ZIP payload.	5/94	MITRE T1105 (Ingress Tool Transfer) combined with T1036 (Masquerading via the fake WordPress URI).
URI Path	/wp-content/L/?160244	Emotet	Disguised HTTP request used to fetch the payload (T1036 Masquerading).	N/A	
Filename	BVGIRVlgdJNp9RRpMUXcp.zip	Emotet	The malicious ZIP archive dropped by the C2 server.	0/94	
IP Address	165.227.166.238	Emotet	Secondary C2 / potential exfiltration target over port 8080.	10/94	MITRE T1071.001
IP Address	162.246.19.18	Emotet	Target of heavy outbound SMTPS traffic (port 465) for spam propagation.	0/94	MITRE T1566 (Phishing)
IP Address	36.95.27.243	Trickbot	Initial C2 server receiving infected host registration data.	1/94	MITRE T1071.001
IP Address	103.102.220.50	Trickbot	Secondary C2 server receiving infected host registration data.	3/94	MITRE T1071.001
IP Address	5.199.162.3	Trickbot	Secondary payload server (likely Cobalt Strike) receiving beacons every 6 seconds.	1/94	MITRE T1071.001 for the beaconing and potentially T1059 (Command and Scripting Interpreter) if commands were being executed.
URI Path	/rob87/ & /tot108/	Trickbot	Campaign IDs and system profiling strings used during botnet registration.	N/A	
File Path	\Policies\...\{...}\gpt.ini	Trickbot	Weaponized Group Policy Object (GPO) located on the DC SYSVOL share, used for lateral movement.	N/A	MITRE T1484.001 (Domain Policy Modification: Group Policy Modification) and T1021.002 (SMB lateral movement).

Figure 7: IOC Table

Mitre Att&Ck Coverage

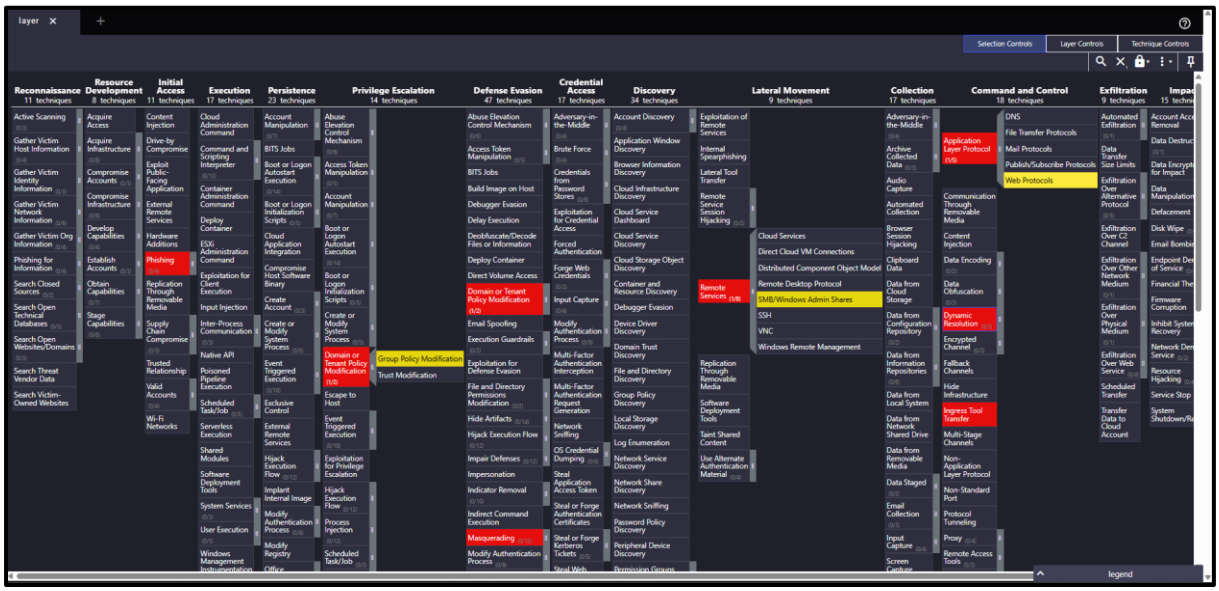


Figure 8: MITRE ATT&CK Navigator Heat Map

The following MITRE ATT&CK techniques were identified and confirmed across the Emotet and Trickbot analysis:

T1105 (Ingress Tool Transfer, Command and Control)
Emotet downloaded the BVGIRVlgdJNp9RRpMUXcp.zip payload from the C2 server at 101.99.3.20.

T1036 (Masquerading, Defense Evasion)
The URI/wp-content/L/?160244 was designed to mimic legitimate WordPress traffic to avoid detection by network monitoring tools.

T1071.001 (Application Layer Protocol: Web Protocols, Command and Control)
HTTP-based C2 communication observed to multiple external servers including port 8080 usage and suspected Cobalt Strike beaconing.

T1566 (Phishing, Initial Access)
The infected host was used as a spam relay sending phishing emails via SMTPS on port 465, propagating the Emotet infection to new targets.

T1219 (Remote Access Software, Command and Control)
Suspected Cobalt Strike frameworks identified through 6-seconds beacon intervals to 5.199.162.3.

T1484.001 (Domain Policy Modification: Group Policy Modification, Persistence and Lateral Movement)
Trickbot accessed the domain controller SYSVOL GPO files via SMB.

T1021.002 (Remote Services: SMB/Windows Admin Shares, Lateral Movement)
SMB-based access to SYSVOL and internal network shares consistent with Trickbot's documented lateral movement behaviour.

Detection Rules Developed

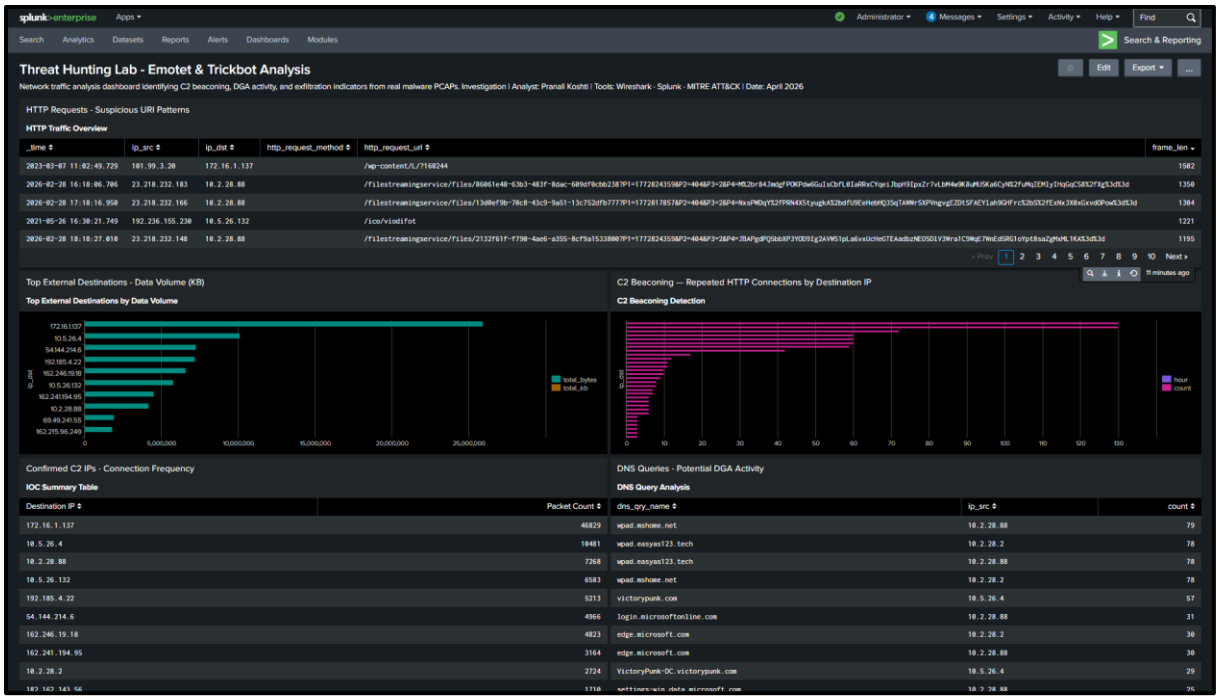


Figure 9: Splunk Dashboard

After completing the Wireshark analysis, I exported the PCAP data to CSV using tshark and ingested all three files into Splunk enterprise under a dedicated index named threat_hunt. I then developed three SPL detection rules based on the behavioral patterns I had identified during packet analysis.

Detection Rule 1: C2 Beaconing

This rule identifies external IP addresses receiving more than 5 HTTP POST requests within a single hour from the internal hosts. Regular high frequency POST requests to the same external destination are a behavioral indicator of C2 beaconing. The rule is designed to catch malware like Emotet that uses HTTP POST for command check-ins.

Detection Rule 2: Dga Domain Detection

This rule flags DNS queries for domain names longer than 20 characters algorithmically generated domain names used by malware to rotate C2 infrastructure tend to be long random looking strings that stand out against normal DNS traffic. High volume of these queries from a single host are a strong indicator of DGA-based malware activity.

Detection Rule 3: Potential Data Exfiltration

This rule identifies external IP addresses that have received more than one MB of large packets from internal hosts large sustained outbound data transfers to external destinations are a behavioral indicator of data staging or exfiltration. The rule flags this activity regardless of the

destination IP's reputation score addressing the gap demonstrated by the low VirusTotal scores in this analysis.

All three roles were saved as production ready Splunk alerts configured to trigger on any matching result.

Key Insights: Behavioral Detection Versus Signature-Based Detection

A consistent pattern emerged across my analysis that I believe is worth highlighting explicitly. The majority of confirmed C2 servers in this exercise scored between zero and five out of 94 on virus total. In up early signature-based detection environment - where alerts are triggered only when a known bad-IP or file hash is matched against a threat intelligence feed - this emoted and tripod infection would have gone largely undetected.

The C2 activity was identified not because these IPs were in any threat feed, but because of what the traffic was doing. A GET request to a single lettered subdirectory on a WordPress site with a numeric query parameter does not look like legitimate browsing behavior. A workstation generating outbound encrypted e-mail traffic is anomalous regardless of where it is sent. A connection that fires with clockwork regularity every six seconds to the same external IP is a beacon regardless of whether that IP has ever been seen before.

This is the core argument for behavioral threat hunting as a complement to automated detection. Attackers who use new or rotating infrastructure - freshly registered domains recently division servers or compromised legitimate sites - can evade signature-based tools indefinitely. Their behavior, however, follows patterns that threat hunters can identify through traffic analysis.
The three Splunk detection rules I developed in this project are all behavioral rules none of them rely on knowing a specific IP address or file hash in advance they detect patterns - frequency, volume, timing, and protocol anomalies – that indicate malicious activity regardless of the specific infrastructure being used.

Recommendations

Based on the findings of this analysis I recommend the following defensive actions:

1. Block the confirmed C2 IP addresses at the perimeter firewall immediately: 101.99.3.20, 165.227.166.238, 162.246.19.18, 36.95.27.243, 103.102.220.50, and 5.199.162.3.

2. Implement DNS filtering for high risk TLD's including .tk, .xyz, and .pw Which are disproportionately associated with malicious domain registrations.

3. Alert on any outbound SMTPS traffic on port 465 originating from non-mail-server-hosts is highly anomalous behaviour that indicates an infected spam relay regardless of the destination IP's reputation score.

4. Deploy A detection rule for HTTP GET requests matching the URI pattern /wp-content/[single character]/? - this is a documented Emotet staging URI structure and any match should be treated as a high confidence indicator of emoted activity.

5. Treat any connection exhibiting regular taken intervals under 10 seconds as a high priority investigation regardless of the destination IP's threat intelligence score. Cobalt strike and similar frameworks are specifically designed to operate below the threshold of what reputation-based tools detect.

6. Deploy the three behavioral SPL detection rules developed in this analysis as permanent production SIEM alerts to provide ongoing coverage for the C2 beaconing DGA and exfiltration patterns identified.

Tools And References

1. PCAP source files: malware-traffic-analysis.net - training exercises section
2. MITRE ATT&CK Framework: attack.mitre.org
3. VirusTotal IOC verification: virustotal.com
4. AbuseIPDB reputation lookup: abuseipdb.com
5. Splunk Enterprise Free: splunk.com
6. Wireshark network protocol analyzer: wireshark.org
7. tshark command line packet analyzer: included with Wireshark installation